

P-SGSI-03: Gestión de Identidades y Control de Acceso (Identity-First)

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

Organización: Universidad Nacional del Centro del Perú (UNCP) **Versión:** 1.0 (Enfoque Zero Trust) **Norma:** ISO/IEC 27001:2022 (Controles A.5.15 - A.5.18, A.8.2 - A.8.5) **Alineamiento:** TRV-01 (Gestión de Identidades IdM/SSO)

1. Filosofía de Control: Zero Trust (Confianza Cero)

La UNCP adopta un modelo de “Nunca confiar, siempre verificar”. El acceso a los activos de información (ERP ADESA, Campus Virtual, SIGA) no depende de la ubicación física (estar en el campus), sino de la verificación sólida de la identidad y la salud del dispositivo.

2. Ciclo de Vida de la Identidad Digital

2.1. Registro y Alta (Onboarding)

- **Estudiantes/Docentes:** Automatizado mediante la sincronización entre el sistema de Admisión/RRHH y el Directorio Activo (Azure AD B2C / Keycloak).
- **Principio de Privilegio Mínimo:** Todo usuario nace con acceso nulo y se le asignan roles estrictamente necesarios para su función.

2.2. Autenticación Robusta (MFA)

- Es obligatorio el uso de **Autenticación de Múltiple Factor (MFA)** para administrativos, docentes y personal con acceso a datos sensibles o privilegios de red.

2.3. Control de Acceso Dinámico (SSO)

- Implementación de **Single Sign-On (SSO)** para eliminar silos de contraseñas.
- **Acceso basado en Riesgo:** El sistema puede solicitar una verificación adicional si detecta un inicio de sesión desde una ubicación inusual o un dispositivo no reconocido.

2.4. Revisión y Baja (Offboarding)

- **Baja Automática:** Al cesar la relación laboral o condición de estudiante, los accesos se deshabilitan en tiempo real mediante la sincronización del IdM.
- **Revisión Trimestral:** Los dueños de activos deben validar la lista de usuarios con privilegios elevados.

3. Gestión de Cuentas Privilegiadas (PAM)

- El personal de la OTI (Administradores de Bases de Datos y Nube) utilizará cuentas nominativas para tareas de administración, quedando prohibido el uso compartido de la cuenta “admin” o “root”.
- Toda acción privilegiada debe ser auditada y registrada en el SIEM.

4. Control de Acceso Físico

- Acceso al Datacenter restringido mediante biometría y registro electrónico.
- Uso de videovigilancia con analítica para detectar accesos no autorizados en zonas críticas.